

POC 5

Upload Seguro de Comprovantes (Manipulação de Arquivos e Segurança)

[Contexto/Objetivo]

O presente estudo buscou solucionar o problema de segurança em sistemas web que permitem o envio de arquivos por usuários. O objetivo foi avaliar a viabilidade de implementar uma camada de upload seguro no sistema de controle financeiro, impedindo que arquivos maliciosos, como scripts PHP disfarçados de imagens, fossem enviados e executados no servidor, caracterizando um ataque de Remote Code Execution (RCE).

[Metodologia]

A implementação foi realizada em PHP orientado a objetos, criando a classe Uploader com três camadas de proteção: verificação de erros no recebimento do arquivo, validação do tamanho máximo de 2MB e verificação do MIME Type real utilizando a classe nativa finfo do PHP, que lê os bytes internos do arquivo ignorando sua extensão o que evita rodar scripts maliciosos disfarçados de imagens. A classe foi integrada à página de cadastro de compras do sistema, e a eficácia foi comprovada tentando enviar um arquivo .php renomeado para .jpg, demonstrando o bloqueio pelo sistema.

[Resultados]

Os resultados demonstraram que a validação por MIME Type real bloqueou com sucesso o envio de arquivos maliciosos, exibindo mensagens ao usuário sem expor detalhes internos do sistema utilizando as Exceptions. Arquivos legítimos foram aceitos e salvos com nomes únicos gerados por uniqid(), evitando sobrescrita e exposição de caminhos previsíveis.

[Conclusão]

Conclui-se que a validação de MIME Type real é *essencial* para sistemas de upload seguros, sendo superior à simples verificação de extensão, e que o uso de OOP facilita o encapsulamento e reutilização dessas regras de segurança em qualquer parte do sistema. **Palavras Chaves:** Orientação a objetos, Segurança Web, Upload de Arquivos.

-Leonardo Hitoshi Ishida RA 250282